

PRÁCTICA 9: ANÁLISIS COMPARATIVO DE VULNERABILIDADES CVE

Esta práctica se dedica al estudio práctico de las CVE (*Common Vulnerabilities and Exposures*) y del sistema de puntuación **CVSS** (*Common Vulnerability Scoring System*). Se trata de seleccionar, comparar y analizar críticamente **tres CVE distintas**, pertenecientes a plataformas diferentes, y demostrar que la búsqueda y el análisis han sido realizados personalmente por el estudiante sobre las bases de datos oficiales.

Índice propuesto

- 1.- Introducción a CVE, CVSS y las principales bases de datos
- 2.- Proceso de selección documentado
- 3.- Ficha técnica comparativa de las tres CVE
- 4.- Análisis individual de cada CVE
- 5.- Análisis comparativo
- 6.- Noticias relacionadas
- 7.- Conclusiones
- 8.- Bibliografía

1. Introducción a CVE, CVSS y las principales bases de datos

Redactar **dos o tres párrafos** que expliquen qué es el programa CVE, quién lo coordina (MITRE), qué papel juegan las CNA (*CVE Numbering Authorities*), cómo funciona el sistema CVSS y qué diferencia hay entre CVE.org, la NVD del NIST y FIRST.org. La **brevedad y la precisión** serán criterio de evaluación en este apartado.

2. Proceso de selección documentado

Este es el apartado más importante para acreditar la autonomía del trabajo. Se estructura en tres subapartados:

2.1. Criterios de selección obligatorios

Las tres CVE seleccionadas deben cumplir simultáneamente los criterios siguientes:

- Publicadas o modificadas en los **últimos 12 meses** (desde abril de 2025 en adelante).
- CVSS Base Score **igual o superior a 9.0** (nivel Crítico).
- Vector de ataque **remoto** (campo *Attack Vector* = Network, AV:N en la

cadena de vector CVSS).

- **Sin autenticación previa** necesaria para el atacante (campo *Privileges Required* = None, PR:N).
- Vulnerabilidad en un **componente del sistema operativo base** o del núcleo de plataforma: NO se admiten CVE que afecten exclusivamente a aplicaciones de terceros (navegadores, suites ofimáticas, reproductores multimedia, etc.).
- Las tres CVE deben pertenecer a **plataformas distintas: Windows** (10/11/Server), **macOS**, **Android**, **iOS/iPadOS** o cualquier distribución de **Linux**.

Indicar en este apartado las tres CVEs seleccionadas y demostrar que cumplen los criterios de selección.

2.2. Capturas de pantalla de la búsqueda y del historial del navegador

Incluir al menos dos capturas de pantalla de la interfaz de NVD (nvd.nist.gov) o CVE.org mostrando la búsqueda con los filtros aplicados antes de seleccionar las CVE definitivas. Las capturas deben mostrar la URL del navegador y la fecha visible del sistema o del navegador. **La tercera captura de pantalla será del historial de navegación** que justifique el trabajo realizado (aconsejamos realizar esta última captura al final del trabajo).

2.3. Candidatos descartados

Elaborar una tabla con al menos **otras tres CVEs que fueron consideradas y se descartaron**, indicando para cada una el motivo concreto del descarte (no cumplía algún criterio obligatorio, fue sustituida por otra de mayor ámbito, etc.):

[Tabla: Identificador CVE | Plataforma | Razón del descarte]

Tras la tabla, redactar un breve párrafo justificando la elección final de las tres CVE seleccionadas.

3. Ficha técnica comparativa

Completar la tabla siguiente con datos extraídos directamente de NVD/CVE.org:

[Tabla de tres columnas, una por CVE, con las filas siguientes:]

Identificador CVE (CVE-AÑO-NÚM)

Plataforma / Sistema Operativo afectado

Versiones afectadas

CVSS Base Score

Vector CVSS completo (cadena AV:x/AC:x/PR:x/UI:x/S:x/C:x/I:x/A:x)

Estado del registro en NVD (ANALYZED, MODIFIED, AWAITING ANALYSIS...)

¿Figura en el catálogo CISA KEV? (Sí/No + enlace si procede)

¿Existe PoC público documentado? (Sí/No + fuente)

Fecha del primer parche oficial

¿Era un 0-day en el momento de publicación del CVE? (Sí/No, justificar brevemente)

4. Análisis individual de cada CVE

Dedicar una sección a cada una de las tres CVE. Cada sección debe contener los subapartados siguientes:

4.1.- CVE-XXXX-XXXXX

Origen y descubrimiento

Cómo se descubrió la vulnerabilidad, quién la notificó, fechas clave (reserva del identificador, publicación inicial, última actualización del registro).

Descripción técnica

En qué componente reside el fallo, qué tipo de vulnerabilidad es (desbordamiento de búfer, uso después de liberación, inyección, etc.) y cómo puede ser explotada.

Traducción del vector CVSS al lenguaje natural

Explicar qué significa **concretamente** cada campo del vector CVSS de esta CVE. No basta con definir cada métrica en abstracto: hay que explicar por qué ese campo tiene ese valor en este caso específico. Por ejemplo, si PR es None, explicar por qué el atacante no necesita credenciales; si Scope es Changed, explicar qué sistemas adicionales al vulnerable podrían verse comprometidos.

Impacto real observado

Si se tiene noticia de que la vulnerabilidad fue explotada activamente, describir los hechos conocidos. Si no hay evidencia de explotación, indicarlo explícitamente.

Estado de la mitigación

Parches disponibles, versiones corregidas, posibles medidas de mitigación alternativas y recomendaciones actuales.

(Repetir los apartados 4.2 y 4.3 para las restantes CVEs)

5. Análisis comparativo

Este apartado tiene carácter **crítico y de opinión razonada**. No existen respuestas únicas correctas: se evalúa la coherencia del razonamiento y el uso de criterios técnicos. Debe responder a las siguientes preguntas, dedicando a cada una al menos un párrafo:

Pregunta 1. ¿Cuál de las tres CVE representa un mayor riesgo real para un **usuario doméstico**? ¿Y para una **empresa** con una red corporativa? Argumentar por qué la respuesta puede ser diferente en cada contexto.

Pregunta 2. Comparar la **ventana de exposición** de las tres CVE: tiempo transcurrido entre la publicación del identificador CVE y la disponibilidad del primer parche oficial. ¿Qué implicaciones prácticas tiene una ventana larga para los administradores de sistemas?

Pregunta 3. Si fueras responsable de seguridad de una organización que utiliza las tres plataformas afectadas y dispusieras de **recursos limitados** para aplicar parches, ¿en qué orden priorizarías el tratamiento de las tres CVE? Razonar con criterios distintos al CVSS Base Score (exposición real, criticidad del activo,

existencia de exploit, etc.).

Pregunta 4. Revisar si alguna de las tres CVE tiene entrada en el **catálogo CISA KEV** (*Known Exploited Vulnerabilities*, cisa.gov/known-exploited-vulnerabilities-catalog). ¿Qué significa que una CVE figure en ese catálogo? ¿Cambia tu orden de priorización anterior?

6. Noticias relacionadas

Localizar **una noticia** relacionada con cada una de las tres CVE seleccionadas (total: tres noticias). Para cada noticia, copiar y rellenar la ficha siguiente:

===== FICHA DE NOTICIA (repetir tres veces) =====

CVE a la que se refiere:

Fecha de la noticia:

Título de la noticia:

Enlace a la noticia:

Breve resumen (mínimo 100 palabras):

=====

7. Conclusiones

Reflexión personal (mínimo media página) sobre lo aprendido en la práctica. Se sugiere abordar alguno de los siguientes aspectos, aunque el estudiante puede añadir otros:

- Qué ha resultado más sorprendente o inesperado al analizar las tres CVE.
- Por qué es relevante que los responsables de seguridad sigan periódicamente las publicaciones de NVD, INCIBE-CERT o CISA.
- Qué dificultades ha encontrado el estudiante al buscar y verificar la información en las fuentes primarias.

8. Bibliografía

Referencias en formato **IEEE**. Deben incluirse obligatoriamente las URLs de los registros CVE/NVD de cada una de las tres vulnerabilidades analizadas, la URL del calculador CVSS oficial (nvd.nist.gov/vuln-metrics/cvss) y cualquier otra fuente consultada.

Documentación y entrega

Formato: **documento PDF**, páginas A4 con márgenes de 2 cm.
Extensión mínima: **10 páginas** (sin contar portada ni índice). El documento estará precedido de **portada** e **índice**.

Portada:

En formato libre, contendrá el texto siguiente:

SI — CURSO 2025-2026 — PRÁCTICA 9 — [NOMBRE Y APELLIDOS]

ANÁLISIS COMPARATIVO DE VULNERABILIDADES:

CVE-XXXX-XXXXX - CVE-XXXX-XXXXX - CVE-XXXX-XXXXX

Modalidades de entrega:

Los estudiantes que **siguen la asignatura por curso** defenderán personalmente la práctica al profesor en el laboratorio.

Los estudiantes que **no siguen la asignatura por curso** deberán subir el programa completo de prácticas a la plataforma en convocatoria extraordinaria o especial, en las fechas indicadas en la página de la asignatura.

Recursos de referencia (entre otros):

nvd.nist.gov

cve.org

first.org/cvss

cisa.gov/known-exploited-vulnerabilities-catalog

incibe.es/incibe-cert

